
ChurchGeniusPro

Information Security Policy & Procedures

An operationalized program to identify, mitigate, and monitor information security risk

Aligned to SOC 2 (Trust Services Criteria), ISO/IEC 27001, NIST CSF 2.0, and OWASP ASVS / Top 10

Version 1.0

Effective date: July 1, 2026

Next scheduled review: July 1, 2027 (or upon material change)

Owner: Chief Information Security Officer / Security Lead

Classification: Internal

Scope note. This document describes the security program as applied to the ChurchGeniusPro platform — a Spring Boot application with a PostgreSQL data store serving a member portal and staff portal that process member PII, financial/donation records, and children's-ministry data. Controls described as “in place” reflect the current implementation; controls marked as “planned” or listed in the risk register (Section 12) are committed remediations with owners and dates.

Contents

1. Purpose
 2. Scope and Environment
 3. Framework Alignment
 4. Governance, Roles and Responsibilities
 5. Information Security Risk Management Process
 6. Asset and Data Classification
 7. Access Control, Authentication and Authorization
 8. Application Security (OWASP)
 9. Data Protection, Cryptography and Secrets Management
 10. Logging, Monitoring and Detection
 11. Secure Development and Change Management
 12. Risk Register (Identified Risks and Treatment)
 13. Vulnerability and Patch Management
 14. Backup, Availability and Resilience
 15. Third-Party and Sub-Processor Security
 16. Incident Response
 17. Personnel and Endpoint Security
 18. Metrics, Monitoring Cadence and Continuous Improvement
 19. Policy Governance and Review
- Appendix A — Control-to-Framework Mapping
- Appendix B — OWASP Top 10 Coverage
- Appendix C — Incident Response Runbook (Summary)

1. Purpose

This policy establishes ChurchGeniusPro's documented, operationalized approach to information security. It defines how the organization identifies information security risks, mitigates them with layered controls, and continuously monitors both the controls and the threat environment. It exists to protect the confidentiality, integrity, and availability (CIA) of the data entrusted to the platform — particularly congregation member personal data, financial contribution records, and children's-ministry information — and to satisfy customer, contractual, and regulatory security expectations.

2. Scope and Environment

This policy applies to all information systems, source code, data, personnel, and third parties involved in operating the ChurchGeniusPro platform. The in-scope environment is:

- **Application:** a single Spring Boot service exposing a REST API and serving a static front end (member portal and staff/church-admin portal).
- **Data store:** PostgreSQL, holding member/family profiles, contributions and pledges, program enrollment, accounts, and HTTP sessions (Spring Session JDBC).
- **Authentication:** session-based, enforced by a custom servlet-filter chain (there is no Spring Security filter chain; BCrypt is used for password hashing).
- **Integrations / sub-processors:** SMTP email, Twilio SMS, WhatsApp messaging, OpenAI (vision OCR, transcription), and Web Push (VAPID).
- **Tenancy:** multi-tenant; records are isolated by an application client identifier (appClientId).
- **Deployment:** production runs under the “prod” profile over HTTPS; logs are written to rolling files.

3. Framework Alignment

The program is designed to map to multiple recognized frameworks so it can support customer due diligence, audits, and certification efforts without duplication:

Framework	How it is used in this program
SOC 2 (Trust Services Criteria)	Primary lens for the Security, Availability, and Confidentiality criteria used in customer security reviews.
ISO/IEC 27001 (ISMS + Annex A)	Structures the risk-management lifecycle (Section 5) and control domains (Sections 7–17).
NIST CSF 2.0	Organizes controls under Govern, Identify, Protect, Detect, Respond, and Recover functions.
OWASP ASVS / Top 10	Drives application-layer control requirements and the secure-development checklist (Section 8, Appendix B).
General best practice	Fills gaps not addressed by a specific framework (e.g., defense-in-depth, least privilege).

4. Governance, Roles and Responsibilities

Govern (NIST CSF). Security is owned at the leadership level and delegated through defined roles:

Role	Responsibility
Security Lead / CISO	Owns this policy, the risk register, and the security roadmap; approves exceptions; reports to leadership.
Engineering	Implements and maintains controls in code and infrastructure; performs secure development and code review.
Data Protection Officer	Coordinates with the data retention/privacy program and handles data-subject and breach obligations.
Operations / DevOps	Manages secrets, backups, patching, monitoring, and production access.
All staff and contractors	Complete security training, follow this policy, and report suspected incidents promptly.

Security responsibilities are documented, and least privilege applies to every role. Exceptions to this policy require written CISO approval, a compensating control, and an expiry date.

5. Information Security Risk Management Process

Risk management is the core of this program and runs as a continuous, documented cycle. Every risk is recorded in the risk register (Section 12) with an owner, treatment, and monitoring method.

5.1 Identify

- Maintain an inventory of assets, data flows, integrations, and sub-processors.
- Identify threats and vulnerabilities via code review, dependency scanning, penetration tests, threat modeling of new features, log review, and intake of vendor and CVE advisories.
- Capture risks from changes (new integrations, schema changes, new data types such as children's data).

5.2 Assess and Prioritize

Each risk is scored on **likelihood** and **impact** (1–5 each) to yield a risk rating. Impact considers data sensitivity (member PII, financial, children's data carry the highest weight), regulatory exposure, and availability. Ratings drive priority and target remediation timelines:

Rating	Score	Target remediation
Critical	20–25	Immediate — within 7 days or emergency change
High	12–19	Within 30 days
Medium	6–11	Within 90 days
Low	1–5	Backlog / accept with review

5.3 Treat

For each risk a treatment is selected: **mitigate** (add or strengthen a control — the default), **transfer** (e.g., contractual or insurance), **avoid** (remove the exposure), or **accept** (documented, time-boxed, CISO-approved). Mitigations map to the control domains in Sections 7–17.

5.4 Monitor and Review

- The risk register is reviewed at least quarterly and whenever a significant change or incident occurs.
- Key risk indicators and control metrics (Section 18) are tracked to detect drift.
- Residual risk is re-scored after treatment; accepted risks are re-evaluated at each review.

6. Asset and Data Classification

Data is classified to drive proportionate controls. Handling requirements increase with sensitivity.

Classification	Examples in the platform	Baseline handling
Restricted	Children's-ministry data, financial/donation records, credentials, API secrets	Strictest access controls, encryption in transit, minimization, audit logging, no use in non-prod

Classification	Examples in the platform	Baseline handling
Confidential	Member/family PII, contact details, communications	Role-based access, tenant isolation, encryption in transit
Internal	Application logs, configuration, operational data	Access limited to staff; no public exposure
Public	Marketing pages, public login page	Integrity protected; no confidentiality requirement

7. Access Control, Authentication and Authorization

Protect (NIST CSF) — identity and access management. The following controls are in place:

7.1 Authentication

- Passwords are hashed with **BCrypt (work factor 10)** via a single central utility; plaintext passwords are never stored. Any legacy plaintext row is re-hashed on the next successful login.
- Sessions are server-side and persisted to PostgreSQL (Spring Session JDBC). Session cookies are set **HttpOnly** with **SameSite=Lax**; the **Secure** flag must be enforced in production (HTTPS-only).
- Idle session timeout is 30 minutes by default; an opt-in “no auto-logout” preference is available for member convenience and should be risk-reviewed.
- A break-glass bypass token exists for off-network administrator recovery and must be stored as a secret, rotated, and monitored for use.

7.2 Authorization and Isolation

- A custom servlet-filter chain enforces access on every request: authentication gating for /api/* endpoints, plus filters for temporary-access expiry, network-restricted (“private”) pages, and NTAG allowed-page restrictions.
- The auth filter re-validates account status (enabled / not deleted) on every request, so disabling or deleting an account takes effect immediately rather than at session expiry.
- Role- and permission-based checks (RoleGuard and permission keys such as accounting.pledges) enforce least privilege for staff functions.
- **Multi-tenant isolation** is enforced by scoping data access to the session's appId; every data query must be tenant-scoped.
- Access is provisioned on least-privilege and reviewed periodically; production access is limited to authorized operations personnel.

8. Application Security (OWASP)

Application-layer controls follow OWASP ASVS and address the OWASP Top 10 (see Appendix B):

- **Injection:** data access uses JPA/parameterized queries; native queries use bound parameters. Raw string-concatenated SQL is prohibited.
- **Cross-site scripting:** output is escaped in the front end, and a **Content-Security-Policy** header is applied to every response by a dedicated filter.
- **Broken access control:** enforced server-side by the filter chain, RoleGuard, and mandatory tenant scoping — never by the client alone.
- **Security misconfiguration:** security headers, disabled directory exposure, least-privilege service accounts, and environment separation are required (see risk register for headers to add).
- **Vulnerable components:** dependencies are inventoried and scanned; see Section 13.
- **Sensitive data exposure:** restricted data is minimized, encrypted in transit, and excluded from non-production and verbose logs.

- **CSRF:** state-changing endpoints must be protected (SameSite cookies provide partial defense; anti-CSRF tokens are a committed enhancement — see risk register).
- **File upload:** multipart size limits are enforced (15 MB/file, 20 MB/request); uploaded images are validated and handled out of the web root.

9. Data Protection, Cryptography and Secrets Management

- **In transit:** production traffic is served over HTTPS/TLS; outbound SMTP uses STARTTLS (required) with TLS 1.2.
- **At rest:** the database and backups must use storage/disk encryption; restricted fields are minimized and access-controlled.
- **Key material:** the Web Push VAPID private key, Twilio, and OpenAI keys are supplied via environment variables — not committed to source.
- **Secrets management:** all credentials must be injected via environment variables or a secrets manager and excluded from the repository. A committed SMTP credential in configuration is a known finding tracked in the risk register for removal and rotation.
- **Data minimization and retention:** handled by the companion Data Deletion & Retention Policy; security controls enforce those retention limits.

10. Logging, Monitoring and Detection

Detect (NIST CSF). Operational controls:

- Application and access events are logged to rolling files (10 MB rotation, 30 files retained); session/login attributes are recorded for traceability.
- Logs must exclude secrets and restricted data; verbose DEBUG logging for the application package must be reduced in production (tracked as a finding).
- Logs should be shipped to centralized, tamper-evident storage with alerting on security-relevant events (auth failures, privilege changes, break-glass token use).
- Availability and error monitoring cover the application and database connection pool.

11. Secure Development and Change Management

- Changes are version-controlled and peer-reviewed before merge, with security-relevant changes receiving additional review.
- Threat modeling is performed for features that introduce new data types or integrations.
- Dependency and static analysis run in the pipeline; builds fail on high-severity findings.
- **Database schema:** production currently uses Hibernate auto-DDL (update). Migrating to managed, reviewed migrations (e.g., Flyway/Liquibase) with ddl-auto=validate is a committed change (see risk register) to prevent uncontrolled schema drift.
- Secrets are never committed; the repository is scanned for secrets and history is remediated when exposures are found.
- Production deployments are authorized, logged, and reversible.

12. Risk Register (Identified Risks and Treatment)

The register below records current, platform-specific risks with treatment and monitoring. It is reviewed at least quarterly. Ratings use the scale in Section 5.2.

Risk	Rating	Treatment / mitigation	Monitoring
Committed SMTP credential in source config	High	Move all credentials to environment variables/secrets manager; rotate the exposed credential; add secret scanning to CI; purge from history.	CI secret scans; periodic repo audit
Verbose DEBUG logging in production	Medium	Set production log level to INFO/WARN; add log redaction for PII/secrets; centralize logs.	Log-level config review; sampling of prod logs
Hibernate auto-DDL (update) in production	Medium	Adopt managed migrations; set ddl-auto=validate; review schema changes.	Deploy checks; schema diff review
No anti-CSRF tokens on state-changing endpoints	Medium	Add CSRF tokens (SameSite=Lax already mitigates); verify cookie Secure flag in prod.	AppSec test suite; pen-test
Incomplete security response headers	Medium	Add HSTS, X-Content-Type-Options, X-Frame-Options/frame-ancestors, Referrer-Policy alongside existing CSP.	Header scan in CI; external scan
Legacy plaintext password fallback path	Medium	Complete migration of all rows to BCrypt; remove the plaintext-equality fallback.	Query for non-BCrypt rows; alert if >0
Children's & financial data concentration	High	Enforce strictest access, minimization, encryption, and audit logging; restrict who can view children's records.	Access reviews; audit-log monitoring
Sub-processor data exposure	Medium	Maintain sub-processor register; require DPAs and equivalent security; least-data sharing.	Annual vendor review; register audit
Extended/no-auto-logout member sessions	Low	Risk-review the opt-in; cap absolute session lifetime; re-auth for sensitive actions.	Session config review

13. Vulnerability and Patch Management

- Dependencies (Spring Boot, libraries) are inventoried and scanned continuously; CVE advisories are triaged against the register's severity/timeline scale.
- Runtime, database, and OS patches are applied on a defined cadence, with emergency patching for critical vulnerabilities.
- Periodic vulnerability scans and independent penetration testing validate controls; findings enter the risk register.

14. Backup, Availability and Resilience

Recover (NIST CSF) / SOC 2 Availability.

- Automated database backups run on a defined schedule; a backup service supports export/restore.
- Backups are encrypted, access-restricted, and periodically test-restored to validate recoverability.
- The connection pool (HikariCP) is tuned for stability; sessions are persisted so restarts do not force mass logout.
- Recovery objectives (RPO/RTO) are defined, documented, and reviewed; deleted records are not reintroduced from backups (see Retention Policy §12).

15. Third-Party and Sub-Processor Security

- A current register of sub-processors (email, SMS/WhatsApp, OpenAI, push) is maintained.
- Each sub-processor is bound by a data-processing agreement requiring equivalent security and confidentiality.
- Only the minimum data required is shared; keys are scoped and rotated; access is revoked on termination.
- Sub-processors are reviewed at least annually and before onboarding new integrations.

16. Incident Response

Respond (NIST CSF). A documented incident-response process governs detection through lessons learned; the runbook summary is in Appendix C.

- All staff report suspected incidents immediately to the Security Lead.
- Incidents are triaged by severity; critical incidents trigger the on-call escalation path.
- Containment, eradication, and recovery steps are executed and documented.
- Breach-notification obligations are coordinated with the DPO and legal per applicable law and contracts.
- A post-incident review captures root cause and corrective actions, which feed the risk register.

17. Personnel and Endpoint Security

- Staff and contractors complete security-awareness training at onboarding and annually.
- Background checks are performed where lawful and appropriate for roles with restricted-data access.
- Endpoints used for administration must have disk encryption, screen lock, and up-to-date protection.
- Access is granted on hire per least privilege and fully revoked promptly on role change or departure.

18. Metrics, Monitoring Cadence and Continuous Improvement

Metric / indicator	Cadence
Open risks by rating; overdue remediations	Monthly
Secret-scan and dependency-scan findings	Per build + weekly summary
Authentication failures / anomalies; break-glass token use	Continuous alerting
Non-BCrypt password rows remaining	Monthly (target: 0)
Backup success rate and last successful test-restore	Weekly
Patch latency for critical vulnerabilities	Per event + monthly
Access review completion; sub-processor review status	Quarterly / annually

19. Policy Governance and Review

- This policy is owned by the Security Lead/CISO and approved by leadership.
- It is reviewed at least annually and after any major incident or significant change.
- Version history and approvals are recorded; exceptions are logged with expiry dates.
- Non-compliance may result in disciplinary action and, for vendors, contractual remedies.

Appendix A — Control-to-Framework Mapping

Control domain (this policy)	SOC 2 TSC	ISO 27001 (Annex A)	NIST CSF 2.0
Risk management (§5, §12)	CC3.x	A.5 / Clause 6	GV, ID.RA
Access control / IAM (§7)	CC6.1–6.3	A.5.15–5.18, A.8.2–8.5	PR.AA
Application security (§8)	CC7.1, CC8.1	A.8.25–8.28	PR.PS, PR.PS-06
Data protection / crypto (§9)	CC6.7, C1.x	A.8.10–8.12, A.8.24	PR.DS
Secrets management (§9)	CC6.1	A.8.24, A.5.17	PR.DS, PR.AA
Logging / detection (§10)	CC7.2	A.8.15–8.16	DE.CM, DE.AE
Secure SDLC / change (§11)	CC8.1	A.8.25, A.8.31–8.32	PR.PS, ID.RA
Vulnerability mgmt (§13)	CC7.1	A.8.8	ID.RA, PR.PS
Backup / availability (§14)	A1.x	A.8.13, A.5.29–5.30	RC.RP, PR.DS-11
Third-party mgmt (§15)	CC9.2	A.5.19–5.22	GV.SC, ID.RA
Incident response (§16)	CC7.3–7.4	A.5.24–5.28	RS, RC
Personnel / endpoint (§17)	CC1.4	A.6.1–6.6, A.8.1	PR.AT, PR.PS

Appendix B — OWASP Top 10 Coverage

OWASP Top 10 (2021)	Status	How it is addressed
A01 Broken Access Control	In place	Server-side filter chain, RoleGuard, mandatory tenant scoping, immediate account revalidation.
A02 Cryptographic Failures	Partial	TLS in transit, BCrypt hashing; at-rest encryption and secrets hardening tracked in register.
A03 Injection	In place	JPA / parameterized queries; concatenated SQL prohibited.
A04 Insecure Design	In place	Threat modeling for new data/integrations; least privilege by design.
A05 Security Misconfiguration	Partial	CSP applied; add HSTS/other headers; disable prod DEBUG; move off auto-DDL.
A06 Vulnerable Components	In place	Dependency inventory and scanning; patch cadence (§13).
A07 Auth Failures	Partial	BCrypt, server-side sessions, HttpOnly/SameSite; complete plaintext migration; consider MFA for staff.
A08 Software / Data Integrity	In place	Peer-reviewed, version-controlled changes; authorized deployments.
A09 Logging & Monitoring	Partial	Rolling logs present; centralize, add alerting, redact PII.
A10 SSRF	In place	Outbound calls limited to known providers; validate/allow-list external requests.

Appendix C — Incident Response Runbook (Summary)

1. Detect & report	Anyone who suspects an incident notifies the Security Lead immediately with what, when, and where.
2. Triage & classify	Assign severity (Critical/High/Medium/Low) based on data sensitivity, scope, and availability impact.
3. Contain	Isolate affected systems/accounts; rotate compromised credentials and tokens; preserve evidence and logs.
4. Eradicate	Remove the root cause (malware, vulnerable component, misconfiguration, exposed secret).
5. Recover	Restore service from clean backups; validate integrity; re-apply any pending deletions before returning to service.
6. Notify	Coordinate with DPO/legal on breach-notification duties to authorities, customers, and individuals per law/contract.
7. Review	Conduct a blameless post-incident review; record root cause and corrective actions in the risk register.

Note. This policy documents the target-state security program and the current implementation status of each control. Items marked “Partial”, “planned”, or listed in the risk register are committed improvements with owners and timelines, tracked through the quarterly risk review.